

MODULE 12 · DOMAIN 5 - SECURITY, COMPLIANCE & GOVERNANCE

Security, Compliance & Governance

Domain 5 — mostly ordinary AWS security, applied to AI workloads.

DOMAIN 5 of 5 EXAM WEIGHT 14% MODULE 12 of 14

AWS secures the **infrastructure**. You secure your **data, your access, and how you use the model**.

IAM is the first control, always

- ◆ **IAM policies** decide who may invoke which model, and which actions they may take.
- ◆ **Least privilege** — grant only what the task requires, nothing broader.
- ◆ **Roles, not keys.** Applications assume roles rather than carrying credentials.
- ◆ **IAM Identity Center** handles workforce identity, and is what makes Q Business permission-aware.
- ◆ If a question asks who can access a model or dataset, the answer is IAM.

ON THE EXAM

IAM is the single most common correct answer in this domain. Access control questions rarely have a more exotic answer.

At rest, in transit, and who holds the key

- ◆ **AWS KMS** manages encryption keys. Default encryption uses AWS-managed keys.
- ◆ **Customer managed keys** give you control of rotation, policy and revocation.
- ◆ Data in transit is protected with TLS across all AWS services.
- ◆ Training data, model artefacts and inference logs can all be encrypted.
- ◆ Encryption protects data at rest and in motion. It does not control **who may read it** — that is IAM.

ON THE EXAM

'We must control our own encryption keys' means a customer managed key in KMS. That phrasing appears verbatim.

Keeping traffic off the internet

- ◆ **VPC endpoints powered by AWS PrivateLink** reach Bedrock without traversing the internet.
- ◆ Traffic stays on the AWS network. No internet gateway, no public IP needed.
- ◆ SageMaker training jobs and endpoints can run inside your VPC.
- ◆ Security groups and network ACLs apply as they do to any workload.
- ◆ This is about the **path** the traffic takes, not about who is allowed to call.

ON THE EXAM

'Without traffic leaving the AWS network' or 'without using the public internet' means PrivateLink and VPC endpoints.

Five services people mix up

SERVICE	ANSWERS THE QUESTION
CloudTrail	Who called which API, when, and from where?
CloudWatch	How is it performing right now? Metrics, logs, alarms.
AWS Config	Is this resource configured the way policy requires?
Audit Manager	Can I produce evidence for a compliance framework?
AWS Artifact	Where are AWS's own compliance reports, like SOC and ISO?

ON THE EXAM

CloudTrail records actions. CloudWatch records performance. Config records configuration state. Three different questions.

CloudTrail or CloudWatch?

CLOUDTRAIL

Who did what

- Records API calls as audit events
- Identity, timestamp, source IP, parameters
- Answers governance and forensic questions
- CloudTrail Lake lets you query that history

CLOUDWATCH

How is it doing

- Metrics, logs and alarms
- Latency, invocation counts, error rates
- Answers operational questions
- Triggers alerts and automated responses

THE TIEBREAKER

Audit and accountability means CloudTrail. Performance and operations means CloudWatch. The word 'who' is the giveaway.

Macie, and what it is not

- ◆ **Amazon Macie** discovers and classifies sensitive data sitting in S3.
- ◆ Finds PII, credentials and financial data in buckets, and reports what it finds.
- ◆ Useful before building a knowledge base, to know what you are about to index.
- ◆ **Amazon Inspector** scans workloads for software vulnerabilities. Different job entirely.
- ◆ **Amazon GuardDuty** detects threats and unusual activity. Also different.

ON THE EXAM

Macie for data discovery, Inspector for vulnerabilities, GuardDuty for threats. All three appear together as options.

Security services that are usually wrong answers

SERVICE	WHAT IT ACTUALLY DOES
Amazon Inspector	Scans for software vulnerabilities and network exposure.
Amazon GuardDuty	Detects threats and anomalous account behaviour.
AWS Trusted Advisor	Recommends cost, performance and security improvements.
AWS Shield	DDoS protection.
AWS WAF	Filters malicious web requests.
AWS Secrets Manager	Stores and rotates credentials.

ON THE EXAM

These are real services that rarely answer an AI question. Recognising them as distractors saves time on the exam.

What AWS does with your data

- ◆ Your prompts and outputs are **not used to train the base models**.
- ◆ Fine-tuning data stays yours. A custom model is private to your account.
- ◆ **Model invocation logging** sends prompts and responses to S3 or CloudWatch for audit.
- ◆ Model access must be explicitly requested per model in the account.
- ◆ Enabling invocation logging means prompts are stored. Protect that store like any sensitive data.

ON THE EXAM

'Will our prompts train Amazon's models' is a recurring question. The answer is no.

Where data lives and how long it stays

- ◆ **Residency** — choose the Region, because data stays where you put it.
- ◆ **Retention** — S3 lifecycle policies delete or archive on a schedule.
- ◆ **Lineage** — knowing which data trained which model version.
- ◆ **SageMaker Catalog** governs discovery and permissions for data and model assets.
- ◆ Classification first: you cannot govern data you have not categorised.

ON THE EXAM

'Data must not leave the country' is a Region choice, not an encryption or IAM question.

Proving it to someone else

- ◆ **AWS Artifact** — download AWS's own audit reports: SOC, ISO, PCI.
- ◆ **AWS Audit Manager** — continuously collect evidence about **your** workloads.
- ◆ Frameworks: GDPR, HIPAA, PCI DSS, ISO 42001 for AI management systems.
- ◆ Artifact is about AWS. Audit Manager is about you. Same split as service cards and model cards.
- ◆ Compliance is continuous, not a one-off certificate.

ON THE EXAM

Auditor wants proof about AWS infrastructure? Artifact. Proof about your own workload? Audit Manager.

The threats that are not ordinary security

- ◆ **Prompt injection** and **prompt leaking** — covered in Module 5. Inference-time attacks.
- ◆ **Data poisoning** — corrupting training data. A training-time attack.
- ◆ **Model inversion** — extracting training data from model behaviour.
- ◆ **Excessive agency** — an agent granted more permission than its task needs.
- ◆ Guardrails, least privilege and human review are the controls that map to these.

ON THE EXAM

These are the risks IAM and encryption do not cover. That is precisely why the exam separates them out.

Carry these into the exam

- ◆ Who may access it? IAM. How is it encrypted? KMS. Which path does traffic take? PrivateLink.
- ◆ Who called the API? CloudTrail. How is it performing? CloudWatch.
- ◆ Sensitive data in S3 means Macie. Not Inspector, not GuardDuty.
- ◆ AWS's compliance reports means Artifact. Evidence about your workload means Audit Manager.
- ◆ Data must stay in-country means choose the Region.
- ◆ Your Bedrock prompts do not train the base models.

A security team is asked which employee invoked a particular foundation model at 03:14 last Tuesday, and from which IP address.

They need this for an internal investigation.

Which service provides it?

- ☐ A Amazon CloudWatch
- ☐ B AWS CloudTrail
- ☐ C AWS Config
- ☐ D Amazon Inspector

◆ PAUSE AND DECIDE

Which service provides it?

- A

 CloudWatch
Performance metrics and logs. Not identity of the caller.
- B

 CloudTrail
Records who called which API, when, and from where.
- C

 AWS Config
Records configuration state, not API calls.
- D

 Amazon Inspector
Scans for vulnerabilities. Unrelated.

ON THE EXAM

'Which employee' and 'from which IP' are both identity questions. CloudTrail is the only service that records them.

A defence contractor must call Amazon Bedrock from applications in a private subnet. Security policy forbids any traffic to the public internet, and there is no internet gateway. The applications must still reach the Bedrock API.

What should they configure?

- ☐ A A NAT gateway
- ☐ B A VPC endpoint using AWS PrivateLink
- ☐ C An IAM policy allowing bedrock:InvokeModel
- ☐ D AWS WAF

◆ PAUSE AND DECIDE

What should they configure?

- A

 NAT gateway
Routes to the internet. Exactly what policy forbids.
- B

 VPC endpoint with PrivateLink
Traffic reaches Bedrock without leaving the AWS network.
- C

 IAM policy
Grants permission. Does not create a network path.
- D

 AWS WAF
Filters inbound web requests. Wrong direction.

ON THE EXAM

Option C is the sharpest distractor: permission and connectivity are different problems, and this scenario is about connectivity.

Before indexing twelve thousand documents into a knowledge base, a bank wants to know which of them contain customer account numbers or national insurance numbers.

The documents are in Amazon S3.

Which service should they run first?

- | | |
|---|---|
| ☐ A Amazon GuardDuty | ☐ B Amazon Inspector |
| ☐ C Amazon Macie | ☐ D AWS Config |

◆ PAUSE AND DECIDE

Which service should they run first?

- A

 GuardDuty
Detects threats and unusual activity. Not data content.
- B

 Inspector
Scans workloads for vulnerabilities. Not data content.
- C

 Macie
Discovers and classifies sensitive data in S3.
- D

 AWS Config
Checks resource configuration, not file contents.

ON THE EXAM

All four are real security services. Only one looks inside the objects. That is what makes this question work.

A healthcare provider must encrypt its training data and model artefacts, and its regulator requires the organisation to be able to revoke access to that data independently of AWS. They also want key rotation under their own control.

What meets the requirement?

- ☐ A Default encryption with AWS-managed keys
- ☐ B A customer managed key in AWS KMS
- ☐ C An IAM policy denying access
- ☐ D AWS Secrets Manager

◆ PAUSE AND DECIDE

What meets the requirement?

- A

 AWS-managed keys
Encrypts, but you do not control policy or rotation.
- B

 Customer managed KMS key
You control the key policy, rotation and revocation.
- C

 IAM deny policy
Controls access, but the requirement is key control.
- D

 Secrets Manager
Stores credentials, not data encryption keys for training data.

ON THE EXAM

'Under their own control' and 'independently of AWS' both point at customer managed keys rather than default encryption.

An external auditor asks a company to provide AWS's SOC 2 report as evidence that the underlying cloud infrastructure is independently certified.

The company does not need to produce evidence about its own configuration for this request.

Where do they get it?

- | | |
|--|---|
| ☐ A AWS Audit Manager | ☐ B AWS Artifact |
| ☐ C AWS CloudTrail | ☐ D AWS Config |

◆ PAUSE AND DECIDE

Where do they get it?

- A

 Audit Manager
Collects evidence about your workloads, not AWS's certifications.
- B

 AWS Artifact
The download portal for AWS's own audit reports.
- C

 CloudTrail
Your API history. Not a certification.
- D

 AWS Config
Your configuration state. Not a certification.

ON THE EXAM

The scenario says explicitly that no evidence about their own setup is needed. That single line separates Artifact from Audit Manager.

A European insurer is legally required to keep all customer data and all processing of it within the EU.

It plans to build a generative AI assistant on Amazon Bedrock.

What is the primary control?

- ☐ A Encrypt everything with KMS
- ☐ B Deploy in an EU Region and use models available there
- ☐ C Apply Bedrock Guardrails
- ☐ D Use IAM policies to restrict access

◆ PAUSE AND DECIDE

What is the primary control?

- A

 Encrypt with KMS
Good practice, but encrypted data in the wrong Region is still there.
- B

 Deploy in an EU Region
Residency is a Region choice. Data stays where you put it.
- C

 Guardrails
Controls content, not geography.
- D

 IAM policies
Controls who accesses data, not where it sits.

ON THE EXAM

Every wrong option is a genuine best practice. None of them changes which continent the data is on.

A legal team asks whether confidential contract text entered as prompts into Amazon Bedrock could later appear in responses given to other AWS customers.

They want a clear answer before approving the project.

What is correct?

- ☐ A Yes, prompts are used to improve the base models
- ☐ B No, prompts and outputs are not used to train the base models
- ☐ C Only if invocation logging is enabled
- ☐ D Only for open-weight models

◆ PAUSE AND DECIDE

What is correct?

- A

 Yes, used for training
Incorrect. AWS states prompts do not train base models.
- B

 No, not used for training
Your data stays yours; base models are unchanged.
- C

 Only with logging enabled
Logging stores prompts in your account. It does not share them.
- D

 Only for open-weight models
Invented distinction. Not how Bedrock works.

ON THE EXAM

Option C is worth understanding: invocation logging does store prompts, but in your own S3 or CloudWatch, not anywhere shared.

A company runs a customer-facing agent that can issue account credits. Its execution role currently permits all actions on the billing system.

A reviewer flags this as the highest risk in the design.

Which principle is being violated, and what is the fix?

- | | |
|---|---|
| ☐ A Encryption in transit; enable TLS | ☐ B Least privilege; scope the role to the specific action |
| ☐ C Data residency; move to another Region | ☐ D Transparency; publish a model card |

◆ PAUSE AND DECIDE

Which principle is being violated, and what is the fix?

- A

 Encryption in transit
Already handled by TLS, and unrelated to permissions.
- B

 Least privilege
Scope the role to issuing credits within defined limits.
- C

 Data residency
Geography. Nothing to do with over-broad permissions.
- D

 Transparency
Documentation does not reduce what the agent can do.

ON THE EXAM

This is excessive agency from the AI risk list, and the fix is ordinary IAM. AI-specific risks often have conventional controls.